



**OFICINA DE SOLUÇÕES
PROFISSIONAIS**

ORIENTAÇÕES

OFICINA DE SOLUÇÕES PROFISSIONAIS

Disciplina: Segurança e Auditoria de Sistemas
Unidade: 1- Segurança da Informação

Encontro 1 – Estudo de Caso

Neste encontro, você analisará um caso específico relacionado à área de atuação do curso e desenvolverá propostas práticas aprofundando o entendimento teórico.

Você deverá concluir a atividade e apresentá-la ao final do encontro.

1. Objetivo da Atividade:

Mapear, classificar e propor contramedidas para os riscos de segurança da informação a partir do cenário apresentado.

2. Descrição da Atividade:

A empresa TechStore Ltda. é uma loja virtual de médio porte que comercializa eletrônicos pela internet. Ela possui um servidor web próprio, banco de dados com informações de clientes (nome, CPF, endereço, dados de cartão de crédito), sistema de e-mail corporativo e acesso remoto via VPN para funcionários. Recentemente, a empresa passou por dois incidentes: um funcionário acessou dados de clientes sem autorização, e o site ficou fora do ar por 6 horas devido a um ataque de negação de serviço (DDoS). A diretoria decidiu realizar um levantamento formal dos riscos de segurança da informação para prevenir novos incidentes.

Para identificar e analisar os riscos presentes nesse cenário, é fundamental ter em mente os princípios da segurança da informação:

- **Confidencialidade:** garantir que apenas pessoas autorizadas acessem as informações (ex.: dados de cartão de crédito dos clientes).
- **Integridade:** assegurar que as informações não sejam alteradas de forma não autorizada (ex.: registros de pedidos e pagamentos).
- **Disponibilidade:** manter os sistemas e informações acessíveis sempre que necessário (ex.: site de vendas online).
- **Autenticidade:** confirmar a identidade dos usuários que acessam o sistema (ex.: funcionários com VPN).

Para construir a tabela de mapeamento de riscos, serão necessários os seguintes elementos:

- Probabilidade (P): indica a chance de o risco ocorrer — Baixa (1), Média (2) ou Alta (3).
- Impacto (I): indica a gravidade das consequências caso o risco se concretize — Baixo (1), Médio (2), Alto (3) ou Extremo (4).
- Risco (P x I): resultado da multiplicação — classifique conforme a legenda: 1 = Insignificante; 2 e 3 = Baixo; 4 e 6 = Médio; 8 e 9 = Alto; 12 = Extremo.
- Contramedida: ação preventiva ou corretiva que reduz a probabilidade ou o impacto do risco. Justifique indicando qual princípio CID é protegido.

3. Etapas para Realização:

- Identifique pelo menos 5 (cinco) riscos de segurança da informação presentes no cenário da TechStore Ltda.;
- Para cada risco identificado, atribua uma pontuação de Probabilidade (1, 2 ou 3) e de Impacto (1, 2, 3 ou 4), conforme a escala apresentada na Figura 1;
- Calcule o valor do risco (P x I) e classifique-o como: Insignificante, Baixo, Médio, Alto ou Extremo;
- Proponha ao menos uma contramedida (ação preventiva ou corretiva) para cada risco mapeado, justificando sua escolha.

GABARITO:

Olá, Tutor (a). O aluno(a) deverá desenvolver um Mapeamento e classificação de Riscos de acordo com o problema proposto. Como resultado esperado, teremos algo parecido como:

Risco Identificado	Probabilidade (P)	Impacto (I)	P x I	Classificação	Contramedida Proposta (princípio CID protegido)
Acesso indevido a dados de clientes por funcionário	3 (Alta)	3 (Alto)	9	Alto	Controle de acesso baseado em perfil (RBAC) e registro de logs de auditoria. (Confidencialidade)
Ataque DDoS derrubando o site	2 (Média)	4 (Extremo)	8	Alto	Firewall com proteção anti-DDoS, CDN e plano de continuidade de negócios. (Disponibilidade)
Vazamento de dados de cartão de crédito via banco de dados	2 (Média)	4 (Extremo)	8	Alto	Criptografia de dados sensíveis em repouso e em trânsito (TLS/AES). (Confidencialidade)

Risco Identificado	Probabilidade (P)	Impacto (I)	P x I	Classificação	Contramedida Proposta (princípio CID protegido)
Comprometimento de credenciais VPN de funcionários	2 (Média)	3 (Alto)	6	Médio	Autenticação multifator (MFA) para acesso VPN e política de senhas fortes. (Autenticidade)
Phishing por e-mail corporativo	3 (Alta)	2 (Médio)	6	Médio	Filtro antispam/antiphishing, treinamento de conscientização para funcionários. (Integridade)
Falha no servidor web (indisponibilidade por manutenção ou falha)	1 (Baixa)	3 (Alto)	3	Baixo	Redundância de servidor e monitoramento contínuo com alertas automáticos. (Disponibilidade)

LEGENDA:

Risco (P x I)	Classificação
1	Insignificante
2 e 3	Baixo
4 e 6	Médio
8 e 9	Alto
12	Extremo

A TechStore já vivenciou dois incidentes reais — acesso indevido por funcionário e ataque DDoS. A partir disso, foram mapeados 6 riscos representativos do ambiente descrito.

Risco 1 — Acesso indevido a dados de clientes por funcionário

P=3, I=3, resultado 9 → Alto

A probabilidade é alta porque o incidente já aconteceu, ou seja, não há controles de acesso adequados. O impacto é alto porque envolve dados pessoais sensíveis (CPF, cartão de crédito), podendo gerar sanções da LGPD. A contramedida principal é o RBAC (Role-Based Access Control), que garante que cada funcionário acesse apenas o que seu cargo exige — protegendo a Confidencialidade.

Risco 2 — Ataque DDoS

P=2, I=4, resultado 8 → Alto

Probabilidade média porque o ataque já ocorreu uma vez, mas não é contínuo. O impacto é

extremo porque uma loja virtual fora do ar significa perda direta de receita e dano à reputação. Contramedidas como CDN com proteção anti-DDoS e plano de continuidade protegem a Disponibilidade.

Risco 3 — Vazamento do banco de dados de cartões

P=2, I=4, resultado 8 → Alto

Probabilidade média pois ainda não ocorreu, mas o banco está exposto. O impacto é extremo — vazamento de dados financeiros tem consequências legais graves (LGPD, PCI-DSS). Criptografia dos dados em repouso e em trânsito protege a Confidencialidade.

Risco 4 — Comprometimento de credenciais VPN

P=2, I=3, resultado 6 → Médio

Probabilidade média porque funcionários remotos são alvos comuns de phishing e ataques de força bruta. O impacto é alto porque uma VPN comprometida abre acesso à rede interna. A autenticação multifator (MFA) protege a Autenticidade, exigindo uma segunda prova de identidade além da senha.

Risco 5 — Phishing por e-mail corporativo

P=3, I=2, resultado 6 → Médio

A probabilidade é alta porque phishing é o vetor de ataque mais comum e não exige nenhuma sofisticação técnica do atacante. O impacto é médio porque depende da ação do funcionário para se concretizar. Filtros técnicos combinados com treinamento humano protegem a Integridade das informações.

Risco 6 — Falha no servidor web

P=1, I=3, resultado 3 → Baixo

Probabilidade baixa pois falhas espontâneas são menos frequentes do que ataques. O impacto, porém, ainda é alto pela indisponibilidade do serviço. A redundância de servidores e o monitoramento contínuo protegem a Disponibilidade com custo relativamente baixo.

Lógica geral da classificação:



Os três riscos classificados como Alto envolvem dados diretamente comprometidos ou serviço totalmente interrompido — são os que exigem ação imediata. Os dois Médios dependem de falha humana para se concretizar, o que os torna controláveis com política e treinamento. O Baixo tem impacto real mas probabilidade reduzida, sendo tratável com infraestrutura de contingência.